

Catalogue des profils d'infrastructure

Document de choix — à lire par tous les groupes

DOCUMENT
Catalogue

PROMOTION
Master 1



Sommaire

Document de choix — à lire par tous les groupes	3
1. Vue d'ensemble	3
2. Les sept profils	3
A — MécaNord Industries	3
B — Clinique Saint-Roch	4
C — PayFlux	4
D — Ville de Beauval-sur-Escaut	4
E — MaisonVerte	4
F — NexaHost	5
G — Laboratoire LARIS	5
3. Comment choisir	5
4. Procédure de choix	6
5. Ce que contient un cahier des charges	6

Document de choix — à lire par tous les groupes

Sept entreprises fictives, sept systèmes d'information à construire. Chaque groupe en choisit **un** et le réalise pendant la phase de build.

Ce document est le seul que toute la promotion reçoit. Le cahier des charges complet d'un profil — la liste exacte des services, les zones, les jeux de données, les comptes — n'est remis qu'au groupe qui a choisi ce profil. Vous ne saurez donc pas ce que votre cible a construit, et elle ne saura pas ce que vous avez construit.

1. Vue d'ensemble

Profil	Entreprise	Secteur	Zone spécifique	Services	Charge
A	MécaNord Industries	industrie mécanique, sous-traitance aéronautique	atelier de production (OT)	16	moyenne
B	Clinique Saint-Roch	santé — clinique privée	imagerie et biomédical	16	élevée
C	PayFlux	fintech — éditeur SaaS de paiement	fabrique logicielle (CI/CD)	16	élevée
D	Ville de Beauval-sur-Escout	collectivité territoriale	vidéoprotection urbaine	16	moyenne
E	MaisonVerte	retail — e-commerce et 12 magasins	caisses et logistique	16	moyenne
F	NexaHost	infogérance et hébergement	environnements clients infogérés	17	élevée
G	Laboratoire LARIS	enseignement supérieur et recherche	calcul et données de recherche	16	moyenne

Colonne « Services » = tranche ferme, tous obligatoires. Chaque profil comporte en plus une tranche conditionnelle de 3 services, valorisée mais non exigée.

2. Les sept profils

A — MécaNord Industries

Industrie mécanique · 380 salariés · usinage de précision pour l'aéronautique

Un sous-traitant de rang 2 qui vit sur deux informatiques qui ne se parlent pas : une gestion modernisée en 2019, et une informatique industrielle installée avec les lignes de production en 2011, gérée par le bureau des méthodes et jamais renouvelée. Un prestataire automatique intervient à distance sur l'atelier. L'entreprise décroche un marché qui impose une certification de la chaîne d'approvisionnement, d'où l'audit.

- **Zone spécifique** : le réseau de l'atelier (OT), qui ne doit être atteignable que par une passerelle de maintenance.

- **Actifs critiques** : les plans de fabrication des donneurs d'ordre, le carnet de commandes, la disponibilité des lignes.
- **Ce que vous allez travailler** : le cloisonnement IT/OT, les accès prestataires, des services d'âges très différents dans un même SI.
- **À choisir si** vous voulez un SI classique et lisible, avec un vrai enjeu de segmentation.

B — Clinique Saint-Roch

Santé · 220 salariés et 60 praticiens libéraux · clinique polyvalente

Un établissement certifié qui héberge des données de santé, infogéré par une ESN régionale, avec un accès permanent laissé aux fournisseurs biomédicaux pour la télémaintenance des équipements d'imagerie, et un accès distant ouvert dans l'urgence en 2020 pour les praticiens libéraux. Le serveur d'imagerie ne s'arrête jamais, donc il n'est jamais maintenu.

- **Zone spécifique** : le réseau biomédical — imagerie et équipements médicaux communicants.
- **Actifs critiques** : les dossiers patients, les examens d'imagerie, la continuité de soin.
- **Ce que vous allez travailler** : la contrainte réglementaire (RGPD, données de santé), la traçabilité des accès, les accès tiers permanents, un protocole métier peu courant.
- **À choisir si** vous acceptez de monter un service d'imagerie médicale à la main : c'est le profil le plus dépayçant, et le plus exigeant côté intégration.

C — PayFlux

Fintech · 85 salariés · plateforme SaaS d'encaissement pour commerçants

Quatre ans d'existence, une dette technique proportionnelle à la vitesse de livraison. Tout est conteneurisé, tout part en production plusieurs fois par jour depuis une chaîne d'intégration, et la gestion des secrets applicatifs n'a jamais été formalisée. Un investisseur exige un test d'intrusion.

- **Zone spécifique** : la fabrique logicielle — dépôts de code, intégration continue, artefacts, secrets.
- **Actifs critiques** : les données de transaction, l'intégrité de ce qui part en production, la disponibilité de l'API.
- **Ce que vous allez travailler** : une chaîne de livraison qui fonctionne réellement, une API et un espace client cohérents, l'observabilité applicative.
- **À choisir si** l'équipe est à l'aise avec Docker, Git et les pipelines : c'est le profil le plus moderne, et celui qui demande le plus de choses fonctionnelles de bout en bout.

D — Ville de Beauval-sur-Escaut

Collectivité territoriale · 28 000 habitants · 410 agents

Deux agents à la DSI, un budget contraint, un parc constitué au fil de trois mandatures. Les logiciels métiers d'état civil et d'urbanisme datent et leur remplacement est repoussé depuis 2019, tandis que le portail de démarches en ligne a été livré en 2024 dans un plan de transformation numérique. La vidéoprotection, installée en 2018, n'a plus été touchée depuis la réception des travaux. La médiathèque offre un Wi-Fi public.

- **Zone spécifique** : la vidéoprotection urbaine.
- **Actifs critiques** : les données d'état civil et d'urbanisme, les flux vidéo, l'image de la collectivité.
- **Ce que vous allez travailler** : la cohabitation ancien/moderne, l'isolation d'un réseau ouvert au public, la conformité RGPD d'un service public.
- **À choisir si** vous voulez beaucoup de services mais tous classiques : c'est le profil le plus accessible techniquement.

E — MaisonVerte

Retail · 540 salariés · jardinerie en ligne et 12 magasins

Une enseigne passée en quelques années du tout-magasin à l'omnicanal. La boutique en ligne, développée par une agence externe, pèse 40 % du chiffre d'affaires ; les caisses et la logistique sont gérées en interne par une équipe issue du monde du magasin. Les deux univers communiquent par des traitements nocturnes et des interfaces bricolées au fil de l'eau.

- **Zone spécifique** : les magasins et l'entrepôt — encaissement, consolidation des ventes, gestion des stocks.
- **Actifs critiques** : le chiffre d'affaires en ligne, les données clients, la continuité de l'encaissement.
- **Ce que vous allez travailler** : un parcours d'achat qui fonctionne vraiment, des flux batch entre deux mondes, un site à fort trafic avec cache et moteur de recherche.
- **À choisir si** vous voulez un SI où la donnée métier est visible et vivante : c'est le profil qui se prête le mieux au réalisme.

F — NexaHost

Infogérance et hébergement · 60 salariés · 180 clients sous contrat

Le prestataire informatique de 180 PME. Son SI est la clé de voûte de celui de ses clients : un portail de tickets par lequel arrive tout, une base de connaissance qui centralise les procédures d'intervention, un point de rebond unique vers tous les parcs administrés, et une offre d'hébergement mutualisé où les clients cohabitent. Plusieurs clients exigent désormais par contrat un test d'intrusion sur le prestataire lui-même.

- **Zone spécifique** : deux environnements clients réellement administrés par NexaHost.
- **Actifs critiques** : le point de rebond et les moyens d'accès aux clients, la base de connaissance, la cloison entre les environnements hébergés.
- **Ce que vous allez travailler** : la concentration de privilèges, l'isolation multi-locataires, le scénario d'attaque par la chaîne d'approvisionnement.
- **À choisir si** l'équipe est solide : c'est le profil le plus fourni (17 services) et le plus retors, mais aussi le plus spectaculaire à auditer.

G — Laboratoire LARIS

Enseignement supérieur et recherche · 1 800 étudiants · 30 permanents, 25 doctorants

Une culture d'ouverture assumée : les services sont largement accessibles et chaque équipe déploie les outils dont elle a besoin, parfois hors de toute procédure de la direction du numérique. Un annuaire unique gère étudiants et personnels, avec une politique de mot de passe volontairement souple pour les comptes étudiants. Deux projets sont sous embargo de publication au titre de conventions industrielles.

- **Zone spécifique** : les moyens de recherche — calcul, environnements d'analyse, stockage des données.
- **Actifs critiques** : les jeux de données et les travaux non publiés, le code des projets partenariaux, la disponibilité de la plateforme pédagogique en période d'examens.
- **Ce que vous allez travailler** : une population énorme et hétérogène, des outils de traitement de données, la séparation étudiants / personnels.
- **À choisir si** vous voulez un SI orienté données et calcul, avec un scénario d'espionnage académique.

3. Comment choisir

Tous les profils demandent le même travail de fond : **16 ou 17 services à déployer, dont 12 porteront une vulnérabilité**, 3 points d'entrée, 2 chaînes d'exploitation, la même documentation et la même recette. Le choix porte donc sur le **terrain**, pas sur la quantité.

Quelques repères :

Vous voulez...	Regardez
un SI classique, lisible, avec un bel enjeu de cloisonnement	A ou D
de la donnée métier riche et un parcours utilisateur complet	E
du moderne : conteneurs, dépôts de code, chaîne de livraison	C
de la donnée sensible et une contrainte réglementaire forte	B
des outils de traitement de données et du calcul	G
le profil le plus dense et le plus vicieux	F
limiter le risque si l'équipe est peu expérimentée	A, D ou E

Deux points à considérer avant de trancher :

- **B** impose de monter un service d'imagerie médicale qui ne se trouve pas dans les catalogues habituels : prévoyez-y du temps.
- **C** et **F** exigent des outils réellement fonctionnels (une chaîne d'intégration qui construit et déploie, un hébergement mutualisé à plusieurs sites) : c'est du travail d'intégration avant d'être du travail de sécurité.

4. Procédure de choix

1. Le groupe lit ce catalogue et se met d'accord sur **un profil**.
2. Le chef de groupe déclare le choix à l'équipe pédagogique **avant la fin de la première demi-journée de build**, avec un second choix en cas d'arbitrage.
3. L'équipe pédagogique confirme l'attribution et remet au groupe **le cahier des charges complet** du profil retenu.
4. Ce cahier des charges ne se diffuse pas hors du groupe. Il contient la liste exacte des services, les zones, les jeux de données et les comptes attendus : le communiquer à un autre groupe revient à lui donner la carte de votre SI.

L'équipe pédagogique veille à ce qu'un groupe et le groupe qu'il attaque ne construisent jamais le même profil. Deux groupes sans lien d'appariement peuvent en revanche recevoir le même profil : leurs infrastructures resteront différentes, puisque le placement des vulnérabilités, des chaînes et des flags appartient à chaque groupe.

5. Ce que contient un cahier des charges

Pour information — ce que vous recevrez une fois votre profil attribué :

§	Contenu
1	Objet du marché
2	Présentation du demandeur — organisation, situation actuelle, actifs critiques
3	Périmètre de la prestation
4	Exigences d'architecture réseau — les six zones et les règles de cloisonnement
5	Exigences fonctionnelles — la liste des services attendus, en lots
6	Exigences de contenu et jeux de données
7	Exigences de sécurité et de conformité

8	Exigences d'exploitation
9	Livrables attendus
10	Critères de recette
11	Annexe — comptes attendus

C'est un cahier des charges **client** : il décrit un besoin métier et rien d'autre. Il ne dit pas quels services rendre vulnérables — cette décision vous appartient, et c'est elle qui fera la différence entre les groupes ayant choisi le même profil.